

---

## NORMA DE CONTROLE DE ACESSO E USO DE CREDENCIAIS

---

**Código:**  
NT-01

**Versão:**  
1.0

**Data de Emissão:**  
10/11/2025

**Público-Alvo:**  
Público Interno e Externo

**Aprovação:**  
Presidência

### 1 Objetivo

Garantir que o acesso a sistemas, dados e recursos tecnológicos da Sentinela Controladoria seja concedido e utilizado de forma segura, conforme o princípio do menor privilégio, reduzindo riscos de vazamento de dados, fraudes financeiras e indisponibilidade de serviços críticos, como o ERP 360 e os dashboards de Business Intelligence.

### 2 Escopo

Esta norma se aplica ao público interno (empregados, estagiários, sócios) e externo (prestadores e parceiros) da Sentinela Controladoria que utilizem sistemas corporativos, tais como o ERP 360, Power BI, e serviços de nuvem associados (Microsoft, Elevor, Evernote e Office).

### 3 Referências Normativas

- 3.1 NIST SP 800-53 Rev. 5: Controles AC e IA;
- 3.2 NIST SP 800-171 Rev. 2: 3.1 (Access Control) e 3.5 (Identification and Authentication);
- 3.3 NIST SP 800-63B: Digital Identity Guidelines;
- 3.4 ISO/IEC 27002:2022: Seções 5.15, 5.16, 8.2, 8.3, 8.4;
- 3.5 LGPD (Lei 13.709/2018): Art. 46 a 50 – Segurança e Boas Práticas.

### 4 Definições

#### 4.1 Credencial

Login, senha ou outro fator de autenticação que identifica o usuário.

#### 4.2 Menor Privilégio

Acesso apenas ao necessário para a função (NIST SP 800-53 AC-6).

#### 4.3 MFA (Autenticação Multifator)

Combinação de fatores distintos para autenticação (NIST SP 800-63B, Sec. 4).

## 4.4 Hash

Função criptográfica irreversível utilizada para proteger senhas (*NIST SP 800-63B – 5.1.1.2*).

## 5 Responsabilidades

### 5.1 Usuários

- 5.1.1 Utilizar credenciais individuais e intransferíveis;
- 5.1.2 Não compartilhar informações de acesso, mesmo com colegas ou superiores;
- 5.1.3 Evitar reutilizar senhas corporativas em contas pessoais;
- 5.1.4 Manter senhas protegidas e não armazená-las em planilhas, anotações ou e-mails;
- 5.1.5 Reportar imediatamente qualquer suspeita de acesso indevido à equipe de Tecnologia.

### 5.2 Equipe de Tecnologia

- 5.2.1 Criar, revisar e revogar acessos conforme autorização formal;
- 5.2.2 Implementar autenticação multifator (MFA) nos sistemas que a suportarem;
- 5.2.3 Garantir o bloqueio de contas inativas por mais de 30 dias;
- 5.2.4 Monitorar logs de acesso e alertas de falha.

### 5.3 Gestores

- 5.3.1 Aprovar pedidos de acesso conforme função;
- 5.3.2 Solicitar a revogação imediata de acessos em caso de desligamento ou mudança de função.

## 6 Diretrizes de Controle de Acesso

### 6.1 Concessão e Revisão

- 6.1.1 O acesso deve ser concedido apenas após autorização do gestor responsável;
- 6.1.2 Contas devem ser individuais, com privilégios mínimos;
- 6.1.3 Revisões trimestrais de acesso serão realizadas pela equipe de Tecnologia;
- 6.1.4 Contas inativas por mais de 30 dias serão bloqueadas automaticamente;
- 6.1.5 Contas de ex-colaboradores devem ser revogadas imediatamente após o desligamento.

### 6.2 Autenticação e Senhas

- 6.2.1 Senhas devem ter no mínimo 12 caracteres, contendo letras, números e símbolos;
- 6.2.2 Troca obrigatória a cada 90 dias e proibição de reutilização das últimas 5 senhas;
- 6.2.3 Armazenamento de senhas somente por meio de hash seguro (bcrypt, PBKDF2, Argon2);
- 6.2.4 O acesso remoto (VPN, ERP 360 fora da rede interna) deve exigir MFA.

### 6.3 Sessões e Contas

- 6.3.1 As sessões devem ser encerradas automaticamente após 15 minutos de inatividade;
- 6.3.2 Após 5 tentativas de login inválidas, a conta deve ser temporariamente bloqueada;

.

6.3.3 Contas administrativas (ex.: suporte ERP, Power BI Service) devem ter uso auditado e nomes diferenciados;

6.3.4 É proibido o uso de contas genéricas ou compartilhadas.

## **6.4 Monitoramento e Auditoria**

6.4.1 Todos os acessos aos sistemas críticos (ERP 360, Power BI) devem ser registrados em log (data, hora, origem e ação).

6.4.2 Logs devem ser armazenados por 6 meses e protegidos contra alteração (NIST SP 800-53 AU-9).

6.4.3 A equipe de Tecnologia deve revisar logs trimestralmente, buscando acessos indevidos.

## **6.5 Público Externo**

6.5.1 Acesso de terceiros (ex.: Elevor, Microsoft) deve ser limitado no tempo e no escopo contratual.

6.5.2 Credenciais temporárias devem expirar automaticamente.

6.5.3 Terceiros devem seguir as mesmas regras de autenticação e confidencialidade da Sentinela.

## **7 Comunicação de Incidentes**

Qualquer indício de vazamento de credenciais, e-mails de redefinição suspeitos, acessos irregulares ao ERP ou Power BI, ou comportamentos anômalos deve ser comunicado imediatamente à Tecnologia, conforme a Norma de Resposta a Incidentes de Segurança (NT-SI-02).

## **8 Sanções**

O descumprimento desta norma constitui falta grave e poderá resultar em medidas disciplinares, conforme o código de conduta da empresa. As sanções incluem, de forma gradual: advertência verbal ou escrita, suspensão, desligamento por justa causa, e, se cabível, medidas legais (cíveis e penais) contra os responsáveis. A Sentinela Controladoria poderá adotar ações legais nos casos de vazamento intencional de informações ou negligência grave na proteção de dados, em conformidade com a legislação vigente e contratos de trabalho. (ISO/IEC 27002, 5.35).

## **9 Revisão e Atualização**

Esta norma será revisada anualmente ou a qualquer tempo em que ocorram mudanças relevantes no ambiente de negócios, nas tecnologias utilizadas, nos requisitos legais/regulatórios de proteção de dados ou nas melhores práticas internacionais que possam afetar as diretrizes aqui estabelecidas. A revisão é de responsabilidade do Comitê de Segurança da Informação em conjunto com a Presidência da Sentinela.